

Projet SIEM & XDR

Besoins du client et objectifs du projet

Synthèse du cahier des charges

1. Contexte

Le client souhaite mettre en place une plateforme de supervision de sécurité de type SIEM et XDR reposant sur des technologies open-source. L'enjeu est de disposer d'une visibilité complète sur son infrastructure et de réelles capacités de détection des menaces, tout en respectant les réglementations en vigueur.

Le projet n'impose pas un outil précis : il s'agit d'analyser, d'évaluer et de sélectionner l'architecture open-source la plus adaptée aux besoins techniques et organisationnels du client.

2. Besoins et attentes du client

- **Supervision centralisée** : un point unique de collecte et d'analyse des journaux de sécurité.
- **Sources hétérogènes** : intégrer postes de travail, serveurs et équipements réseau pour une visibilité complète de l'infrastructure.
- **Détection des menaces** : repérer les événements de sécurité, surveiller l'intégrité des fichiers et les comportements suspects.
- **Solution open-source** : maîtrisable en interne et sans coût de licence.
- **Conformité réglementaire** : respect des standards de cybersécurité reconnus, avec au minimum un socle RGPD (protection des données, gestion des logs, vie privée).
- **Architecture évolutive** : capable de grandir d'un déploiement centralisé simple vers une solution distribuée puis conteneurisée de niveau entreprise.

3. Objectifs du projet

- Concevoir et déployer une plateforme SIEM/XDR fonctionnelle assurant une supervision de sécurité centralisée.
- Démontrer l'intégration de sources de données hétérogènes et la détection d'événements de sécurité.
- Mettre en œuvre la corrélation d'événements entre plusieurs systèmes pour gagner en pertinence de détection.
- Garantir, à terme, la scalabilité, la résilience et l'automatisation de la réponse aux incidents.
- Assurer la conformité aux exigences réglementaires et aux standards de sécurité applicables.
- Aboutir à une architecture optimisée selon les besoins opérationnels, la scalabilité et la sécurité.

4. Exigences de conformité

La conformité est progressive : le socle RGPD est exigé dès le départ, puis les standards se renforcent à mesure que l'architecture monte en maturité.

- **Socle minimal (dès la phase 1)** : RGPD, protection des données et sécurité de la collecte.
- **Niveau intermédiaire** : RGPD + ISO/IEC 27001 (ou HIPAA).
- **Niveau avancé** : RGPD + PCI DSS (protection des données de paiement).

5. Une démarche progressive en trois phases

Pour répondre à ces objectifs, le projet est structuré en trois niveaux de maturité croissante :

Phase	Architecture	Objectifs principaux
1 - Minimal	Tout-en-un (all-in-one)	Valider le concept SIEM/XDR, intégrer les sources hétérogènes, socle RGPD
2 - Intermédiaire	Multi-nœuds (distribuée)	Corrélation d'événements, scalabilité, séparation des rôles ; RGPD + ISO/IEC 27001
3 - Avancé	Multi-nœuds + conteneurs	Plateforme scalable, résiliente et automatisée de niveau entreprise ; RGPD + PCI DSS

En résumé : le client attend une plateforme de supervision open-source, centralisée et conforme au RGPD, capable d'intégrer des sources variées et d'évoluer du simple poste tout-en-un vers une solution distribuée et automatisée de niveau entreprise.